# Security & Privacy Disclosure, Final Report

## Generali Austria App / Generali AT Mobility (com.generali.at.mobility) v2.0.2

A telematics SDK autostarts on boot and scores driving behaviour with a direct effect on insurance tariffs before any visible consent, a Facebook SDK with 4,418 classes collects GPS location pre-consent, an exported clipboard content provider exposes app data to any other installed app, and an undisclosed US-based error-monitoring processor runs pre-consent, unresolved through 111 days and a 22-day-overdue embargo, after the original disclosure itself first bounced in a mail-routing loop

**PUBLIC DISCLOSURE, 17 OCTOBER 2026 — EMBARGO REACHED 25 SEPTEMBER 2026, FOUR FINDINGS REMAIN UNADDRESSED**

| | |
|---|---|
| **Target** | Generali Versicherung AG (Generali Austria), Vienna, Austria |
| **Package** | com.generali.at.mobility (Generali Austria App / Generali AT Mobility) |
| **Version Audited** | v2.0.2 |
| **Platform Audited** | Android, static analysis of the production APK |
| **Initial Disclosure Attempt** | 2026-06-27, to privacy@generali.at, security@generali.at, presse@generali.at — bounced (mail routing loop, Postmaster@generali.at) |
| **First Confirmed Delivery (Resend)** | 2026-06-28, to datenschutz@generali.at, CC Austrian Datenschutzbehoerde |
| **Disclosure / Embargo Date** | 2026-09-25 (extended from an initially stated 2026-09-19) |
| **Report Published** | 2026-10-17 |
| **Overall Severity** | CRITICAL |
| **Findings** | 4 (2 Critical, 2 High) |
| **Correspondence** | 6 messages sent by RFI-IRFOS (1 bounced routing-loop attempt, 1 resend, 4 follow-ups), 0 substantive replies ever received from Generali Versicherung AG |
| **Authorities CC'd** | Austrian Datenschutzbehoerde (dsb@dsb.gv.at) |

security@rfi-irfos.com • rfi-irfos.com
ZVR 1015608684 • GISA 39261441 • UID ATU83405245 • Steuernummer 68 696/8736 • Graz, Austria

## Contents


1 Executive Summary 4

2 Subject & Operator Context 5

3 Engagement Summary 5

4 Findings 6
- 4.1 C1: MOVE Telematik SDK autostarts on every device boot and scores driving behaviour with a direct tariff effect, before any visible consent . . . . . 6
- 4.2 C2: Facebook SDK (4,418 classes) initialises at process start and forwards GPS location to Meta before consent, with Meta never named as a recipient . . . . 7
- 4.3 H1: Exported clipboard content provider readable by any other app on the device without a permission check . . . . . 7
- 4.4 H2: Sentry error-monitoring SDK (1,129 classes) reports to US infrastructure before consent, an undisclosed processor and international transfer . . . . . 8

5 Impact Analysis 8

6 The Complete Chain: A Disclosure That Bounced Before It Could Be Ignored 9

7 Data Protection – Article by Article 10

8 Regulatory & Legal Landscape 10

9 Indicators of Compromise 11

10 Disclosure Timeline & Outcome 11

11 Residual Risk & Recommendations 12

## Executive Summary

Generali Versicherung AG operates the Generali Austria App (package com.generali.at.mobility, marketed as 'Generali AT Mobility'), a telematics-linked insurance companion app. A static analysis of the production Android binary (v2.0.2) found four findings, two CRITICAL and two HIGH.

The app embeds the MOVE Telematik SDK (com.movesdk), which registers a RECEIVE_BOOT_COMPLETED receiver and autostarts on every device boot, before any user interaction with the app, collecting continuous driving-behaviour telemetry that Generali's own marketing material ties directly to insurance tariff calculation. No consent screen is shown before this autostart occurs (C1). Separately, the app embeds a 4,418-class Facebook SDK that initialises via FacebookInitProvider at process start and collects GPS location data, which is forwarded to Meta, again before any consent is obtained, with Meta never named as a recipient and this transfer never disclosed as a distinct purpose (C2). The app also exposes expo.modules.clipboard.ClipboardFileProvider as an exported content provider, readable by any other application installed on the same device without any permission check (H1). Finally, the app ships Sentry error-monitoring instrumentation (1,129 classes) that begins reporting before consent and transmits to Sentry's US-based infrastructure, an international transfer and a processor relationship never disclosed in the app's privacy information (H2).

RFI-IRFOS's original disclosure, sent 27 June 2026 to privacy@generali.at, security@generali.at, and presse@generali.at, failed outright: all three addresses bounced with a 'maximum hop count exceeded, routing loop' error from Generali's own mail infrastructure, meaning the disclosure never reached a human inbox on that attempt. RFI-IRFOS resent the full disclosure the next day, 28 June 2026, to datenschutz@generali.at, CC the Austrian Datenschutzbehoerde, which is the first confirmed successful delivery in this case. Four further follow-ups were sent on 23 July, 9 August, 24 August, and 6 September 2026, each restating the open findings and the days elapsed; the embargo, initially stated as 19 September 2026, was explicitly extended to 25 September 2026 in the 24 August and 6 September follow-ups. Across 111 days since the first confirmed delivery and six messages in total, not one substantive reply was ever received from Generali Versicherung AG.

| ID | Severity | Title |
|---|---|---|
| C1 | CRITICAL | MOVE Telematik SDK autostarts on every device boot and scores driving behaviour with a direct tariff effect, before any visible consent |
| C2 | CRITICAL | Facebook SDK (4,418 classes) initialises at process start and forwards GPS location to Meta before consent, with Meta never named as a recipient |
| H1 | HIGH | Exported clipboard content provider readable by any other app on the device without a permission check |
| H2 | HIGH | Sentry error-monitoring SDK (1,129 classes) reports to US infrastructure before consent, an undisclosed processor and international transfer |

## Subject & Operator Context

Generali Versicherung AG is the Austrian subsidiary of the Generali Group, an Italy-headquartered multinational insurer, operating in Austria from Vienna. The Generali Austria App, internally and publicly referred to as 'Generali AT Mobility' (package com.generali.at.mobility), is a telematics-linked companion app offered to motor insurance customers, combining policy management with driving-behaviour tracking that Generali's own product material describes as a factor in tariff calculation. This audit covers v2.0.2 of the production Android binary.

## Engagement Summary

RFI-IRFOS sent the original disclosure on 27 June 2026 to three addresses, privacy@generali.at, security@generali.at, and presse@generali.at. All three bounced the same day with an identical 'maximum hop count exceeded' routing-loop error returned by Generali's own Postmaster@generali.at, meaning the disclosure never reached a human inbox on this first attempt, a mail-infrastructure failure on Generali's side rather than any error in addressing.

RFI-IRFOS resent the full disclosure the next day, 28 June 2026, to datenschutz@generali.at, CC the Austrian Datenschutzbehoerde, explicitly noting in the resend that the prior delivery to Postmaster@generali.at had bounced. This resend is the first confirmed successful delivery in this case. From this point the correspondence continues as a single thread: RFI-IRFOS sent further follow-ups on 23 July (26 days since the resend), 9 August (43 days), 24 August (58 days), and 6 September 2026 (71 days since confirmed delivery), each restating the four open findings and the days elapsed, each addressed to datenschutz@generali.at and, from 9 August onward, also to additional Generali Austria contact addresses (office.at@generali.com, datenschutz.at@generali.com, presse.at@generali.com, serviceteam@generalibank.at, security@generali.com), CC the Austrian Datenschutzbehoerde throughout. The embargo date, stated as 19 September 2026 in the 28 June resend, was explicitly extended to 25 September 2026 in both the 24 August and 6 September follow-ups. Not one message across this record, from any of the ten addresses contacted, ever received a substantive reply.

## Findings

### C1: MOVE Telematik SDK autostarts on every device boot and scores driving behaviour with a direct tariff effect, before any visible consent

**CRITICAL (CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:L/VA:N/SC:N/SI:N/SA:N, 8.5) — continuous location and driving-behaviour telemetry collected pre-consent, feeding an automated tariff-relevant scoring process**

```
<receiver android:name="com.movesdk.android.MoveBootReceiver" android:exported="true">
  <intent-filter>
    <action android:name="android.intent.action.BOOT_COMPLETED"/>
  </intent-filter>
</receiver>

package: com.movesdk
autostart trigger: RECEIVE_BOOT_COMPLETED, no app launch or consent interaction
    required
declared purpose in app: driving-behaviour scoring tied to insurance tariff
```

**Impact:** The app embeds the MOVE Telematik SDK (package com.movesdk), which registers a RECEIVE_BOOT_COMPLETED broadcast receiver, causing it to autostart on every device boot independent of whether the user has opened the app or interacted with any consent prompt. Once active, the SDK collects continuous driving-behaviour telemetry, including acceleration, braking, and location data, which Generali's own product marketing ties directly to motor-insurance tariff calculation. No consent screen is shown before this autostart and data collection begins. A processing operation that feeds an automated scoring process with a direct financial effect on the data subject's insurance premium, triggered before consent and without an effective means to decline before collection starts, raises the profiling and aut omated-decision-making safeguards of Art. 22 alongside the basic lawfulness requirements of Art. 6 and 7.

### C2: Facebook SDK (4,418 classes) initialises at process start and forwards GPS location to Meta before consent, with Meta never named as a recipient

**CRITICAL (CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:L/VA:N/SC:N/SI:N/SA:N, 7.8) — precise location data transmitted to an undisclosed third party in an insurance app, before any consent interaction**

```
<provider android:name="com.facebook.internal.FacebookInitProvider"
  android:authorities="com.generali.at.mobility.FacebookInitProvider"
  android:exported="false"
  android:initOrder="101"/>

Facebook SDK footprint: 4,418 smali classes
Data observed collected: device identifiers, GPS location
Named as recipient in privacy policy: no
```

**Impact:** The production APK embeds the Facebook SDK as 4,418 smali classes, which registers a FacebookInitProvider content provider that initialises automatically at process start, before any app screen is shown and before any consent interaction. Once initialised, the SDK collects and forwards device and location data, including GPS coordinates, to Meta Platforms. Generali's privacy information does not name Meta as a data recipient, nor does it disclose this transfer as a distinct processing purpose. For an insurance app whose core product already involves location-sensitive telematics data, an undisclosed secondary channel carrying GPS data to an unrelated advertising-technology company compounds the risk.

### H1: Exported clipboard content provider readable by any other app on the device without a permission check

**HIGH (CVSS v4.0 AV:L/AC:L/AT:N/PR:N/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N, 6.5) — any other installed application can query app data via the exported provider**

```
<provider android:name="expo.modules.clipboard.ClipboardFileProvider"
  android:authorities="com.generali.at.mobility.ClipboardFileProvider"
  android:exported="true"/>

Permission required to query: none
Reachable by: any other application installed on the same device
```

**Impact:** The app declares expo.modules.clipboard.ClipboardFileProvider with android:exported=”true” and no permission attribute, meaning any other application installed on the same device can query this content provider directly, without requesting any Android permission and without the user's knowledge. In an insurance app that handles policy, telematics, and (per C1/C2) location data, an exported provider of this kind widens the on-device attack surface available to any other installed app, including malicious ones, well beyond what the component's actual function, clipboard file handling, requires.

### H2: Sentry error-monitoring SDK (1,129 classes) reports to US infrastructure before consent, an undisclosed processor and international transfer

**HIGH (CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N, 5.3) — application telemetry transmitted to a US-based processor never named in the app's privacy information**

```
Sentry SDK: 1,129 smali classes
Initialisation: pre-consent, at application start
Transfer destination: Sentry infrastructure, United States
Named as processor in privacy policy: no
Art. 44 safeguard documented: none identified
```

**Impact:** The app ships Sentry error-monitoring instrumentation (1,129 smali classes), which begins capturing and transmitting application telemetry, including crash reports and contextual device data, before any consent interaction, to Sentry's US-based infrastructure. Generali's privacy information does not name Sentry as a processor, nor does it disclose this as an international transfer requiring an Art. 44 safeguard. Taken together with C1 and C2, this is the third pre-consent data channel identified in a single app, and the second to involve a cross-border transfer outside the EU with no documented legal basis.

## Impact Analysis

This report's two CRITICAL findings share a common thread distinct from a typical consent-banner gap: both C1 and C2 begin collecting data automatically, before the user has seen or interacted with any consent mechanism, and both feed into purposes the app's privacy information does not name. C1 is the more severe of the two because the data it collects, continuous driving-behaviour telemetry, has a stated, direct effect on the data subject's insurance tariff; a processing operation that scores a person before they have consented, for a purpose that changes what they pay, is precisely the scenario Art. 22's automated-decision-making safeguards exist to address. C2 compounds the app's location-data exposure by routing GPS coordinates to an unrelated third party, Meta, that the privacy policy never names. H1 and H2 are more conventional gaps, an overexposed content provider and an undisclosed processor relationship, but both widen the practical consequences of C1 and C2: H1 by exposing app data on-device beyond its intended audience, H2 by adding a second undisclosed cross-border transfer alongside C2's.

What ties all four findings together procedurally is the same failure pattern documented elsewhere in this disclosure series: the original disclosure never reached a human inbox on its first attempt at all, not because it was ignored, but because Generali's own mail infrastructure returned it in a routing loop. Once a working channel was found, the substance of four concrete findings went unanswered for 111 days regardless.

## The Complete Chain: A Disclosure That Bounced Before It Could Be Ignored

Step 1 – First attempt, outright failure: RFI-IRFOS sends the full disclosure on 27 June 2026 to privacy@generali.at, security@generali.at, and presse@generali.at. All three addresses bounce the same day with an identical 'maximum hop count exceeded, routing loop' error from Generali's own Postmaster@generali.at. The disclosure never reaches a human inbox on this attempt.

Step 2 – Resend, first confirmed delivery: RFI-IRFOS resends the complete disclosure the next day, 28 June 2026, to datenschutz@generali.at, CC the Austrian Datenschutzbehoerde , explicitly flagging that the prior delivery had bounced. This is the first confirmed successful delivery in the case, and it states an initial embargo date of 19 September 2026.

Step 3 – Twenty-six days, first follow-up: On 23 July 2026, RFI-IRFOS follows up, restating all four findings in detail. No reply.

Step 4 – Forty-three days, widened recipient list: On 9 August 2026, RFI-IRFOS follows up again, this time also addressing office.at@generali.com, datenschutz.at@generali.com, presse.at@generali.com, serviceteam@generalibank.at, and security@generali.com, in addition to datenschutz@generali.at, CC the Austrian Datenschutzbehoerde. No reply from any of the six addresses.

Step 5 – Fifty-eight days, embargo extended: On 24 August 2026, RFI-IRFOS follows up a third time, restating the findings and explicitly extending the embargo from 19 September to 25 September 2026, citing Art. 33(4) GDPR. No reply.

Step 6 – Seventy-one days since confirmed delivery, final follow-up: On 6 September 2026, RFI-IRFOS sends a final follow-up under REF GENERALI-AT-MOBILITY-2026, restating the complete chronology from the original bounce onward and all four findings cleanly enumerated. No reply follows.

Step 7 – Embargo reached and passed: The embargo, confirmed at 25 September 2026 across two separate messages, passes with all four findings unaddressed.

Step 8 – Publication: This report publishes 22 days after the embargo date. Across 111 days since the first confirmed delivery, and 112 days since the original attempt, six messages were sent to ten distinct Generali-affiliated addresses. Not one substantive reply was ever received.

## Data Protection – Article by Article

Art. 6, Art. 7 GDPR – Lawfulness of processing and conditions for consent: C1's driving-behaviour telemetry collection and C2's GPS transmission to Meta both begin before any consent interaction with the user.

Art. 22 GDPR – Automated individual decision-making: C1's driving-behaviour scoring feeds a process with a stated direct effect on insurance tariff, triggered before consent and without a demonstrated means to decline before collection starts.

Art. 13(1)(e) GDPR – Information on recipients: C2's Meta is never named as a recipient, and H2's Sentry is never named as a processor, in Generali's privacy information.

Art. 44 GDPR – General principle for transfers: H2's Sentry data flow to US infrastructure has no documented Art. 44 safeguard.

Art. 32(1)(b), Art. 5(1)(f) GDPR – Security of processing, integrity and confidentiality: H1's exported, unprotected ClipboardFileProvider falls short of the technical measures these provisions require.

## Regulatory & Legal Landscape

Generali Versicherung AG operates in Austria as the Austrian subsidiary of the Generali Group, placing it under the supervision of the Austrian Datenschutzbehoerde (DSB), CC'd throughout this correspondence from the first confirmed delivery onward.

Fine exposure under GDPR: Art. 83(5) applies to the Art. 6, 7, 22, and 13(1)(e) issues in C1 and C2, up to EUR 20,000,000 or 4% of total worldwide annual turnover. Art. 83(4) applies to the Art. 32, 5(1)(f), and 44 issues in H1 and H2, up to EUR 10,000,000 or 2% of total worldwide annual turnover. For an insurance product whose core proposition already involves tariff-relevant behavioural scoring, a finding that this scoring begins before consent and feeds directly into pricing is the kind of issue a supervisory authority is likely to treat as substantive rather than procedural.

## Indicators of Compromise

The following identifiers, SDK packages, and manifest declarations were extracted from the production APK via static analysis only. No Generali servers, accounts, or infrastructure were probed.

```
C1 -- com.movesdk (MOVE Telematik SDK), RECEIVE_BOOT_COMPLETED autostart receiver

C2 -- Facebook SDK (com.facebook.*), 4,418 smali classes,
  FacebookInitProvider, pre-consent initialisation

H1 -- expo.modules.clipboard.ClipboardFileProvider,
  android:exported="true", no permission attribute

H2 -- Sentry SDK, 1,129 smali classes, pre-consent initialisation,
  transfer destination: United States
```

## Disclosure Timeline & Outcome

2026-06-27 Initial disclosure sent to privacy@generali.at, security@generali.at, presse@generali.at. All three bounce the same day with a routing-loop error from Postmaster@generali.at. Never reaches a human inbox.

2026-06-28 Full disclosure resent to datenschutz@generali.at, CC the Austrian Datenschutzbehoerde, flagging the prior bounce. First confirmed delivery. Embargo stated as 2026-09-19.

2026-07-23 Follow-up sent, 26 days since confirmed delivery. No reply.

2026-08-09 Follow-up sent to six addresses (datenschutz@generali.at, office.at@generali.com, datenschutz.at@generali.com, presse.at@generali.com, serviceteam@generalibank.at, security@generali.com), CC the Austrian Datenschutzbehoerde, 43 days since confirmed delivery. No reply.

2026-08-24 Follow-up sent, 58 days since confirmed delivery, explicitly extending the embargo to 2026-09-25 under Art. 33(4) GDPR. No reply.

2026-09-06 Final follow-up sent under REF GENERALI-AT-MOBILITY-2026, 71 days since confirmed delivery, full chronology and all four findings restated. No reply.

2026-09-25 Embargo date reached (as extended, confirmed across two separate messages). Correspondence record: six RFI-IRFOS messages, one bounce, zero substantive replies.

2026-10-17 This report published, 22 days after the embargo date. All four findings confirmed unaddressed on the basis of the correspondence record.

## Residual Risk & Recommendations

C1 – Immediate: gate the MOVE Telematik SDK's autostart behind an explicit, pre-collection consent screen, and document the Art. 22 safeguards (human review path, right to contest) that apply to any tariff-relevant automated scoring derived from this telemetry.

C2 – Immediate: gate Facebook SDK initialisation behind consent, name Meta as a recipient of GPS location data in the privacy policy, and document the legal basis for this transfer as a distinct processing purpose.

H1 – Near-term: remove android:exported="true" from ClipboardFileProvider or restrict it with a signature-level permission, since no legitimate cross-app use case requires it to be publicly queryable.

H2 – Near-term: name Sentry as a processor and the United States as a transfer destination in the privacy policy, document an Art. 44 safeguard for this transfer, and gate Sentry initialisation behind consent.

Across all findings: review the mail-routing configuration that caused the original disclosure to loop and bounce rather than reach any of the three originally contacted addresses, since the same misconfiguration would equally have blocked a report from a customer, a researcher, or a regulator attempting to reach Generali Austria's own published privacy and security contacts.

**RFI-IRFOS** security@rfi-irfos.com • rfi-irfos.com

ZVR 1015608684 • GISA 39261441 • UID ATU83405245 • Steuernummer 68 696/8736 • Elisabethinergasse 25/10, 8020 Graz, Austria All findings derive from static analysis of the published application using publicly available tooling. No Generali servers, accounts, or infrastructure were probed. Technical evidence is archived under chain of custody and will be provided to regulatory authorities on request. Research conducted under ISO/IEC 29147, the freedom of scientific research (Art. 17 StGG) and GDPR Art. 89. REF GENERALI-AT-MOBILITY-2026.